MoMoGuard — Types d'attaques cyber couvertes

Document de référence sécurité · Mémoire L4 Cybersécurité · 09/07/2026

MoMoGuard agit sur deux niveaux : la détection de fraudes Mobile Money (cœur du projet) et la sécurité technique de la plateforme (serveur + agents Android/Windows).

1. Fraudes ciblant l'utilisateur Mobile Money

Mission principale du projet : protéger les victimes potentielles d'arnaques liées au mobile money en RDC.

Type d'attaque	Réaction de MoMoGuard
Smishing / phishing par SMS	Agent Android + scoring (mots-clés : urgent, code PIN, réactivez…)
Hameçonnage par notification	NotificationCaptureService + filtre local avant envoi
Phishing par lien frauduleux	Détection URLs, TLD suspects (.tk, .xyz), raccourcisseurs
Typosquatting / domaines sosies	Homoglyphes (0range, v0dacom) vs domaines officiels
Faux agent opérateur	Détection « agent Orange », demande de code, confirmez identité
SIM swap / remplacement SIM	Détection PUK, nouvelle SIM, carte SIM remplacée
Vol de code OTP / PIN	Détection demandes de partage de code, OTP, mot de passe
Arnaque au gain / loterie	Félicitations, vous avez gagné, frais pour récupérer
Arnaque au transfert par erreur	Envoyé par erreur, renvoyez l'argent
Fraude USSD	Codes *123# dans le presse-papier (agent Windows)
Liens malveillants connus	Google Safe Browsing (si clé API configurée)
Fichiers dangereux	Surveillance Téléchargements (.exe, .apk, .scr…) — Windows
Phishing navigateur	Historique Chrome/Edge/Firefox/Brave — agent Windows

Mécanisme : score 0–100 → niveau faible / moyen / élevé → alerte admin + notification push si danger élevé.

2. Attaques contre la plateforme MoMoGuard

Contrôles OWASP appliqués sur le serveur Flask et les API.

Type d'attaque	Protection en place
Force brute (login admin)	Rate limiting : 10 tentatives/min sur /login et /login/2fa
Vol de session admin	Cookie HttpOnly, SameSite=Lax, Secure (HTTPS), expiration 8 h
CSRF	CSRFProtect sur tous les formulaires HTML
Accès non autorisé au dashboard	@login_required + WebSocket refusé sans session admin
Usurpation d'identité client	Vérification cryptographique jeton Firebase (verify_id_token)
Faux rapports / spam d'alertes	Agent pré-enregistré + jeton obligatoire + rate limit /report
Spoofing d'UID	UID extrait du jeton Firebase, pas du champ libre uid
Injection SQL	SQLAlchemy ORM (requêtes paramétrées)
XSS	Échappement Jinja2 + escapeHtml() JS + en-têtes CSP
Clickjacking	X-Frame-Options: DENY
MIME sniffing	X-Content-Type-Options: nosniff
Comptes non approuvés	Workflow pending → approved ; refus si non validé
Agents compromis	Blocage admin + refus des rapports
Abus API Firebase	Rate limiting sur /api/auth/firebase, /api/my-reports, /api/fcm-token
DoS applicatif	Limite taille content / metadata sur /report
Désactivation malveillante 2FA	Re-auth mot de passe + code TOTP requis

3. Attaques côté mobile (agent Android)

Type d'attaque	Protection
Extraction de jetons (backup, root)	EncryptedSharedPreferences + allowBackup=false
Interception réseau (MITM)	HTTPS obligatoire en release ; HTTP en debug uniquement
Capture d'écran des alertes	FLAG_SECURE sur Paramètres, MFA, Alertes
Reverse engineering APK	R8/ProGuard activé en release
Surveillance non consentie	Consentement explicite + service foreground visible

4. Limites — ce que MoMoGuard ne couvre pas

À mentionner honnêtement dans le mémoire pour démontrer une analyse de risque complète.

Attaque	Pourquoi non couverte
DDoS réseau (volume massif)	Pas de WAF/CDN ; rate limit en mémoire uniquement
MITM sans HTTPS en production	Possible si mal déployé (certificat absent)
Malware avancé / spyware	MoMoGuard n'est pas un antivirus
Ingénierie sociale en face-à-face	Pas de détection hors messages numériques
Phishing personnalisé sans mots-clés	Scoring par règles contournable
Attaque sur Firebase/Google	Dépendance à des tiers
Accès physique téléphone déverrouillé	Hors périmètre
APT / ransomware	Hors périmètre d'un agent de détection SMS

5. Conclusion pour le mémoire

MoMoGuard est un système de détection et d'alerte orienté vers les arnaques Mobile Money (smishing, phishing par lien, SIM swap, faux agents, arnaques au gain et au remboursement). Sur le plan technique, il intègre des contrôles contre les attaques web classiques (brute force, CSRF, usurpation d'identité, injection SQL, accès non autorisé). Il ne constitue pas une solution de sécurité périmétrique complète, mais une couche de détection consentie couplée à une plateforme de supervision sécurisée.